اللائحة الداخلية لأمن المعلومات وضوابط استخدام الذكاء الاصطناعي

الإصدار 3.2 (المعتمد للعام المالي 2026م) · تسري أحكامه على جميع الموظفين والمتعاقدين

المادة 1: الغرض ونطاق التطبيق

تهدف هذه اللائحة إلى حماية أصول الشركة المعلوماتية، وسجلات المتدربين والعملاء، وضمان استمرارية الأعمال وفق الضوابط الأساسية للأمن السيبراني ونظام حماية البيانات الشخصية. تطبق هذه السياسة بصرامة على كافة العاملين بدوام كامل أو جزئي أو المتعاقدين الخارجيين في كافة فروع المنشأة.

المادة 2: سياسة كلمات المرور وتفعيل التحقق الثنائي (MFA)

1. **معايير تكوين كلمة المرور:** يجب ألا يقل طول كلمة المرور عن 14 خانة، وتحتوي إلزامياً على أحرف كبيرة وصغيرة وأرقام ورموز خاصة.
2. **إلزامية التحقق الثنائي (MFA):** يُحظر الدخول إلى البريد الإلكتروني أو السحابة أو منصة التدريب دون تفعيل تطبيق المصادقة المعتمد (Microsoft Authenticator أو Google Authenticator). ويُمنع الاعتماد على الرسائل النصية القصيرة SMS كخيار وحيد إلا بموافقة أمنية استثنائية.
3. **حظر المشاركة أو التدوين:** يُمنع منعاً باتاً كتابة كلمات المرور على أوراق لاصقة أو حفظها داخل متصفحات الويب غير المعتمدة، أو مشاركتها مع أي زميل مهما كانت رتبته الوظيفية.
4. **صلاحية كلمة المرور:** تنتهي صلاحية كلمات المرور تلقائياً كل 90 يوماً ويجب عدم تكرار آخر 6 كلمات مرور مستخدمة.

المادة 3: سياسة العمل عن بُعد واستخدام الأجهزة (BYOD)

- **الاتصال المشفر:** يُلزم الموظف بتشغيل الشبكة الافتراضية الخاصة بالشركة (Corporate VPN) قبل فتح أي ملف أو قاعدة بيانات داخلية أثناء العمل عن بعد.
- **شبكات الواي فاي العامة:** يُحظر تماماً الاتصال بشبكات Wi-Fi العامة والمفتوحة (كالمقاهي والمطارات) دون تفعيل الـ VPN المشفر وبرامج الحماية من الفيروسات المعتمدة.
- **عزل الأجهزة:** يجب عدم تمكين أفراد العائلة أو أي طرف خارجي من استخدام جهاز العمل المخصص من الشركة تحت أي ظرف.

المادة 4: ضوابط استخدام أدوات الذكاء الاصطناعي التوليدي في العمل

تنبيه هام لكافة الإدارات: أدوات الذكاء الاصطناعي (مثل ChatGPT, Claude, Copilot) هي أدوات مساندة لرفع الكفاءة، ولكن سوء استخدامها يعرض المنشأة لمخاطر تسريب الأسرار والمساءلة القانونية.

1. **حظر مشاركة البيانات المصنفة:** يُحظر إدخال أو رفع القوائم المالية غير المعلنة، أو كشوف الرواتب، أو سجلات المتدربين المتضمنة أرقام الهويات أو الحسابات البنكية، أو الشيفرات المصدرية الحصرية للشركة في نماذج الذكاء الاصطناعي العامة المجانية.
2. **تنقية البيانات وتجريدها (PII Scrubbing):** عند الاستعانة بالذكاء الاصطناعي لصياغة بريد إلكتروني أو مذكرة إدارية، يجب استبدال الأسماء والجهات والمبالغ الحقيقية بعناصر نائبة (مثل: [اسم العميل]، [المبلغ]، [الفرع]).
3. **استخدام أدوات عدم حفظ البيانات (Zero Data Retention):** تشجع الشركة استخدام المنصات التي تتيح وضع الخصوصية وتضمن عدم استخدام بيانات الاستفسار لتدريب النماذج العامة (مثل وضع الأعمال Enterprise أو منصات مثل Duck.ai للأعمال التحريرية العامة).
4. **المسؤولية الإنسانية والتدقيق البشري (Human-in-the-Loop):**
   - يتحمل الموظف الذي أصدر المحتوى المسؤولية الأدبية والإدارية والمالية الكاملة عن أي خطأ أو هلوسة أو اختلاق في التقرير الصادر عنه.
   - لا يجوز استخدام مخرجات الذكاء الاصطناعي لاتخاذ قرارات ترقية أو فصل أو عقوبات تأديبية بحق أي موظف دون تدقيق وتوقيع لجنة بشرية مختصة.

المادة 5: إجراءات الإبلاغ عن الحوادث السيبرانية (Incident Response)

عند الاشتباه في حدوث اختراق أو وصول رسالة تصيد احتيالي مشبوهة أو فقدان جهاز عمل، يُلزم الموظف باتباع التسلسل التالي:

- **الخطوة 1:** فصل كابل الشبكة فوراً أو إيقاف تشغيل الواي فاي عن الجهاز المصاب دون إغلاق الجهاز نفسه لحفظ سجل الذاكرة المؤقتة.
- **الخطوة 2:** الإبلاغ الفوري لمركز عمليات الأمن السيبراني (SOC) خلال مهلة لا تتجاوز **ساعتين (120 دقيقة)** من اكتشاف الخلل.
- **الخطوة 3:** قنوات البلاغ المعتمدة:
  - الخط الساخن الداخلي: **تحويلة رقم (4400)** - متاح 24/7.
  - البريد الأمني المباشر: `soc@futuresolutions.com`

المادة 6: جدول المخالفات والعقوبات التنظيمية

تسري العقوبات التالية بحق كل من يخالف أحكام هذه اللائحة، بالإضافة إلى العقوبات المنصوص عليها في نظام العمل ونظام حماية البيانات الشخصية:

نوع المخالفة	التصنيف	الجزاء المترتب (المرة الأولى)	الجزاء عند التكرار
مشاركة كلمة المرور أو تعطيل التحقق الثنائي MFA عمداً	متوسطة الخطورة	إنذار كتابي أول مع إعادة تدريب أمني إلزامي	حسم يومين من الراتب مع إيقاف صلاحية الدخول عن بعد
رفع بيانات مالية سرية أو سجلات عملاء إلى نماذج ذكاء اصطناعي عامة	جسيمة جداً	حسم 5 أيام من الراتب مع الإحالة للتحقيق الإداري	إنهاء الخدمة بموجب المادة 80 مع التعويض عن الأضرار
التأخر في الإبلاغ عن حادث أمني أو بريد تصيد احتيالي لأكثر من 24 ساعة	متوسطة	تنبيه كتابي وتوثيق في الملف الوظيفي	إنذار كتابي نهائي وحسم يوم واحد
اعتماد تقرير يحتوي على معلومات مختلقة (هلوسة) تسببت في التزام مالي دون مراجعة	عالية الخطورة	تحمل التكلفة المالية الناتجة إن ثبت الإهمال مع لفت نظر	إعفاء من المنصب الإشرافي وحسم 3 أيام

المادة 7: النفاذ والمراجعة الدورية

تصبح هذه اللائحة نافذة المفعول من تاريخ صدورها، وتخضع للمراجعة والتحديث نصف السنوي من قبل لجنة الأمن السيبراني وإدارة الحوكمة لمواكبة التطورات المتسارعة في تقنيات الذكاء الاصطناعي والتهديدات الرقمية.

إعداد: رئيس قسم الأمن السيبراني
م. فهد بن عبدالعزيز المطيري
التاريخ: 1448/05/10هـ

اعتماد: الرئيس التنفيذي
أ. عبدالرحمن بن محمد الشمري
الختم الرسمي للمنشأة